ASSIGNMENT SUBMISSION

ETHICAL HACKING

ASSIGNMENT 1

Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

Course: ITA14 – Ethical Hacking

CO1 | Total Marks: 50

SUBMITTED BY

Name: Adhya M

Register Number: 1925L260002

Introduction

The university plans to assess approximately 20 systems and 50 staff before a major technology upgrade. The systems include the student portal, learning-management system (LMS), university email and campus network. The programme may later expand across the university and include external assessors. Since these systems may contain personal and confidential information, every assessment must be formally approved, limited to a defined scope and carried out without unnecessary disruption.

This assignment proposes an integrated governance framework. It covers authorization, scope and rules of engagement, legal compliance, hacker threat classification, ethical conduct, isolated-lab testing, vulnerability disclosure, reusable documents, validation and scalability. No live exploitation is proposed; practical testing is restricted to an isolated lab or other explicitly approved safe environment.

TASK 1 – Formulate the Enquiry and Framework Blueprint

1.1 Engagement-governance requirements

Area	Requirement for the university
Systems	Student portal, LMS, email service and campus network; initially about 20 systems.
People and stakeholders	University management, IT/security team, system owners, data-protection/legal representatives, department requesters, internal testers and approved external assessors.
Activities	Request assessment, verify authority, define scope, assess threats, perform approved checks, document findings, remediate and disclose responsibly.
Constraints	No testing without written approval; no out-of-scope access; protect personal data; avoid service disruption; observe testing windows; preserve evidence securely.
Growth	Use standard templates, unique engagement IDs, role-based access, central logs and repeatable approval steps so the programme can scale.

1.2 Framework blueprint

The framework operates as a controlled sequence. A department submits a request. The governance team checks ownership and obtains written authorization. The system owner and security team define the scope, testing window, permitted methods and emergency contacts in the Rules of Engagement (RoE). Legal and privacy checks are completed before testing. Threat modelling helps select realistic test scenarios. Any hands-on practice that is not explicitly approved for a live system is performed in the isolated lab. Findings are validated, rated, reported to the owner and handled through coordinated disclosure. Closure requires remediation evidence and approval.

Component	Input	Output / interaction
Authorization	Assessment request and asset ownership	Signed approval and engagement ID; unlocks scope preparation.
Scope and RoE	Approved request, assets and business constraints	In-scope list, exclusions, methods, time window and stop conditions.
Legal and privacy	Jurisdiction, data types and contracts	Legal checklist, data-handling controls and assessor obligations.
Threat model	Assets, likely attackers and risks	Prioritized scenarios that guide safe assessment planning.
Lab testing	Approved test plan and lab assets	Contained validation evidence; never a route to unauthorized production testing.
Disclosure	Verified finding and severity	Restricted report, remediation deadline, status log and closure decision.

1.3 Enquiry questions

- Who has authority to approve an assessment, and how is that approval recorded?
- Which systems, IP addresses, accounts, data and testing periods are included or excluded?

- Which Indian legal and contractual requirements apply when personal data or third-party systems are involved?
- How will testers distinguish authorized activities from actions that exceed the approved scope?
- How will vulnerabilities be verified, reported, remediated and disclosed without increasing risk?

1.4 Design criteria and acceptance tests

Design criterion	Acceptance test
Authorization	Every engagement has a signed approval, named owner, dates and unique ID before work begins.
Scope clarity	Every asset is explicitly listed or excluded; ambiguous assets are treated as out of scope.
Legal and privacy protection	A documented legal/privacy review and data-minimization plan exists before testing.
Safety and continuity	Testing windows, rate limits, backup/restore plan and stop conditions are recorded.
Accountability	Actions, approvals, findings and status changes are logged with timestamps and responsible persons.
Responsible disclosure	Each finding has an owner, severity, remediation target and controlled disclosure decision.
Scalability	Templates and roles can be reused for additional departments and third-party assessors.

Rationale: these criteria directly address the scenario's main risks—unauthorized access, legal exposure, service damage, unclear scope and uncoordinated disclosure.

TASK 2 – Design a Hacker Threat Model and Classification

2.1 Classification criteria

An actor is classified using four questions: (1) does the actor have permission; (2) what is the actor's intention; (3) what capability or resources are available; and (4) what target is likely. Permission and intent are considered first because technical skill alone does not make an actor ethical.

Actor type	Motivation	Typical capability	Likely university targets
White-hat	Improve security with permission	Authorized testing, reporting and remediation support	Portal, LMS, email and network within approved scope
Black-hat	Financial gain, theft, disruption or personal benefit	Credential theft, malware, exploitation and concealment	Student records, staff accounts, email and services
Grey-hat	Curiosity, recognition or mixed motives; may act without permission	May identify weaknesses but exceed authority	Public-facing portal, exposed services or network
Script kiddie	Experimentation, attention or mischief	Uses ready-made tools with limited understanding	Login pages, weak passwords and exposed devices
Hacktivist	Political or social cause, publicity or protest	Defacement, disruption, data leaks or coordinated campaigns	Public website, email and university announcements
Insider	Grievance, profit, curiosity or accidental misuse	Legitimate access that may be misused; knowledge of internal systems	Student/staff records, shared drives and administrative systems
State-sponsored	Intelligence gathering, strategic advantage or disruption	Well-funded, patient and technically advanced operations	Research data, identity systems, email and network infrastructure

2.2 Consistent naming rules

- Use the label 'authorized ethical tester' only when written approval, named identity, scope and time window are all valid.
- Use 'unauthorized external actor' when the person has no permission, regardless of whether the action is harmful or helpful.
- Use 'insider threat' when the actor's access originates from a university role; record whether the behaviour is malicious, negligent or accidental.
- Record motivation and capability separately from the final actor label. Do not infer state sponsorship or hacktivism without supporting indicators.

2.3 Borderline actor and alternatives

Example: a student discovers that a university portal exposes a staff directory and views a small amount of information without permission, then reports the issue privately.

- Alternative A – Grey-hat: the student had no authorization, even though the intention may have been to help.
- Alternative B – White-hat: this label might be suggested because the student reported the weakness responsibly; however, good intent does not create permission.
- Final classification – Unauthorized grey-hat activity, followed by a responsible report. The activity remains unauthorized because no written scope or approval existed. The university should thank the report, ask the student not to access further data, and handle the issue through its reporting channel.

The distinction prevents the university from treating good intentions as a substitute for authorization.

TASK 3 – Create an Ethics and Code-of-Conduct Module

3.1 Ethical principles

- Written authorization: begin only after approval by the designated authority and system owner.
- Agreed scope: access only named assets, accounts, data and time windows.
- Confidentiality: do not copy, disclose or discuss personal or university information outside the approved team.
- Integrity: do not alter, delete or fabricate data; preserve evidence accurately.
- Avoid harm: use safe test methods, minimum necessary requests and agreed rate limits.
- Honest reporting: disclose methods, limitations, evidence and uncertainty accurately.
- Accountability: maintain activity logs and report mistakes or unexpected access immediately.

3.2 Prevention and decision checks

Check	Rule / action
Before each test	Confirm engagement ID, signed approval, asset list, tester identity and validity dates.
During testing	Compare each target with the approved asset list; stop if it does not match.
Sensitive data	Do not browse, export or retain real personal data; use masked samples or lab data wherever possible.
Unexpected access	Stop the activity, do not explore further, secure minimal evidence and notify the engagement lead.
Service impact	Stop immediately if instability, unexpected load or user impact is observed.
End of engagement	Return or securely delete approved working copies and submit the final report.

3.3 Scenario test cases

Scenario	Classification	Code response
Tester checks a named test account during the approved window and records a minimal proof.	Acceptable	Continue within scope and log the evidence.
Tester notices a possible issue on a neighbouring server not listed in the scope.	Borderline / out of scope	Do not test it. Record the observation without probing and request written scope change.
Tester downloads a full student database to prove access.	Unacceptable	Stop, notify the lead and privacy contact, preserve incident details and follow incident response.
Tester finds a service outage during a permitted test.	Stop condition	Stop testing, alert the system owner and assist with safe recovery.
Tester shares a screenshot containing student details in a public chat.	Unacceptable	Escalate as a confidentiality incident; remove access where possible and follow breach procedures.

The module protects trust by ensuring that technical capability is always controlled by permission, necessity, confidentiality and accountability. It also gives testers clear stop-and-escalate instructions.

TASK 4 – Construct a Legal-Compliance Mapping

The university is based in India, so Indian law is the primary legal reference. The Information Technology Act, 2000 (IT Act) is relevant to unauthorized access, damage and disclosure. The Digital Personal Data Protection Act, 2023 (DPDP Act) and its notified commencement schedule are relevant to digital personal data; provisions have phased commencement, so the university must check which provisions are in force on the assessment date. The US Computer Fraud and Abuse Act (CFAA), 18 U.S.C. §1030, is an international comparison and may be relevant where the conduct, systems or jurisdiction have a sufficient US connection. It is not automatically the governing law for an India-only university assessment.

Law / provision	Main relevance	Framework control
IT Act, 2000, s.43	Accessing, copying, extracting, introducing a contaminant, disrupting or damaging a computer resource without permission can attract compensation/penalty consequences.	Signed authorization, exact asset scope, least-privilege accounts, safe methods and activity logs.
IT Act, 2000, s.66	Dishonest or fraudulent acts referred to in s.43 can be criminal computer-related offences; punishment may extend to 3 years' imprisonment or fine up to ■5 lakh, or both.	Identity verification, intent controls, prohibited actions, evidence preservation and escalation.
IT Act, 2000, s.72A	Disclosure of personal information obtained under a lawful contract, with intent/knowledge of wrongful loss or gain and contrary to consent or contract, may attract a penalty up to ■25 lakh under the amended provision.	Confidentiality clauses, restricted report access, no public sharing and secure deletion.
DPDP Act, 2023	Establishes obligations for processing digital personal data; commencement is phased by government notification.	Data inventory, minimization, masking, purpose limitation, access controls and privacy review; verify commencement and applicable rules.
CFAA, 18 U.S.C. §1030	Addresses specified unauthorized access, exceeding authorized access, fraud, damage and related computer activity in the United States.	Do not assume Indian approval authorizes activity in US-connected systems; obtain jurisdiction-specific legal review and explicit system-owner authority.

4.1 Offences, obligations and consequences

Reference	Offence / obligation	Penalty or consequence (summary)
IT Act s.43	Specified acts without permission, including access, copying, introducing contaminants or disruption	Compensation/penalty under the Act; liability depends on the act and current statutory text.
IT Act s.66	Dishonestly or fraudulently doing an act referred to in s.43	Up to 3 years' imprisonment, or fine up to ■5 lakh, or both.
IT Act s.72A	Certain disclosure of personal information in breach of lawful contract and with wrongful-loss/gain intent or knowledge	Penalty may extend to ■25 lakh under the amended provision.
DPDP Act	Processing digital personal data must comply with applicable provisions once in force	Statutory penalties vary by breach; confirm the provision's commencement and applicable rules.
CFAA s.1030	Specified unauthorized access, fraud, damage and related conduct involving protected computers	Criminal penalties vary by offence, intent, harm and prior convictions; civil remedies may also be available.

4.2 Which requirements apply to personal data?

Where testing touches student, staff or other identifiable digital personal data, the university must treat privacy protection as a mandatory design requirement. The IT Act provisions concerning unauthorized access and disclosure remain relevant. The DPDP Act should be included in the compliance review, but the team must check the official commencement notification because different provisions have different effective dates. The university should use synthetic or masked data, restrict access to the minimum necessary, avoid bulk downloads, encrypt any approved evidence, restrict report recipients and securely delete temporary copies. Contracts and third-party processor terms must also be reviewed.

Legal note: this is an academic mapping, not legal advice. The legal office should confirm the latest consolidated legislation, commencement notifications, rules, contracts and jurisdiction before approving a real engagement.

Reference sources: India Code – Information Technology Act, 2000; India Code – Digital Personal Data Protection Act, 2023; Gazette of India notification dated 13 November 2025 on phased commencement; United States Code, 18 U.S.C. §1030.

TASK 5 – Create a Scope and Rules-of-Engagement Document

5.1 Reusable RoE template

Field	Default / example entry
Engagement ID	UAS-2026-001
Purpose	Assess security before the university technology upgrade.
Approving authority	University-authorized IT/security governance officer.
System owner	Named owner for each system; approval recorded separately.
In-scope assets	Only the exact hostnames, IP addresses, applications, test accounts and network segments listed in the signed asset schedule.
Out-of-scope assets	Third-party services, payment gateways, personal devices, production databases not listed, neighbouring networks and any asset without owner approval.
Testing window	Dates and local start/end times approved by the system owner; no activity outside this window.
Permitted techniques	Document review, configuration review, safe vulnerability scanning and limited validation expressly listed in the test plan.
Prohibited techniques	Denial-of-service, destructive payloads, persistence, social engineering, phishing, malware deployment, password spraying, data exfiltration and testing of out-of-scope assets unless separately authorized.
Data handling	Use synthetic/masked data; collect minimum proof; encrypt and restrict any approved evidence.
Emergency stop	Any tester or system owner may stop work for instability, unexpected data exposure or scope uncertainty.
Escalation	Tester → Engagement Lead → System Owner → Security Governance / Privacy / Legal as appropriate.
Sign-off	Approver, system owner, engagement lead and tester signatures with date and version.

5.2 Authorization verification rules

- Verify that the approver is authorized by university policy and that the system owner controls each asset.
- Check that the approval identifies the exact engagement, purpose, testers, assets, dates and permitted methods.
- Confirm that external assessors have signed confidentiality, data-processing and acceptable-use terms.
- Store the signed approval in a restricted repository and record its version and approval timestamp.
- If any field is missing, expired or inconsistent, mark the engagement 'NOT AUTHORIZED' and do not test.

5.3 Derived pre-engagement checklist

Check before start	Yes / No / N/A
Signed authorization is stored and still valid.	_____
All assets match the signed in-scope schedule.	_____
Out-of-scope assets and prohibited methods are understood.	_____
Testing window, rate limits and stop conditions are confirmed.	_____
Test accounts, backups and recovery contacts are ready.	_____
Privacy/legal review and data-handling controls are complete.	_____
All testers have completed the code of conduct and confidentiality terms.	_____
Logging, incident escalation and reporting channels are working.	_____

Start condition: every mandatory item must be 'Yes'. A 'No' blocks the engagement until corrected.

TASK 6 – Build an Authorization and Disclosure Layer

6.1 Authorization workflow

Step	Action	Record produced
1. Request	Department submits purpose, systems, business owner, proposed dates and reason.	Assessment Request Form
2. Triage	Governance team checks business need, asset ownership, risk and third-party dependencies.	Triage decision
3. Legal/privacy review	Review data categories, contracts, jurisdiction and required safeguards.	Compliance approval
4. Scope and RoE	System owner and security lead define assets, exclusions, methods, timing and stop rules.	Versioned RoE
5. Written sign-off	Authorized officer, owner, lead and assessors sign the engagement.	Signed authorization
6. Registration	Assign engagement ID and store all approvals in restricted register.	Authorization log
7. Execution and monitoring	Confirm checklist, monitor logs and record status changes.	Activity and status log
8. Closure	Confirm findings delivered, evidence handled and access revoked.	Closure approval

6.2 Responsible coordinated disclosure process

The university uses coordinated vulnerability disclosure (CVD). A finder sends a confidential report to the university security contact. The security team acknowledges receipt, assigns a tracking number, validates the issue safely and informs the affected system owner. The team rates severity, agrees on remediation, provides progress updates and coordinates any external communication. Disclosure occurs after a fix or mitigation is available, or when an approved risk-based deadline is reached.

Timeline	Action
Within 2 business days	Acknowledge the report and provide a tracking ID.
Within 5 business days	Perform initial validation and identify the system owner.
Within 10 business days	Agree severity, remediation owner and target date; send status to the reporter.
Within 30 days	Target remediation for high-risk findings, where technically feasible; provide a written update if more time is required.
Within 60 days	Target remediation for medium/low findings or document an approved exception and mitigation.
At closure	Retest the fix, update the record and coordinate any public advisory.

These are proposed service targets, not statutory deadlines. Critical vulnerabilities or active exploitation require immediate escalation and a shorter case-specific plan.

6.3 Finding-report format

Field	Required content
Finding ID / engagement ID	Unique reference numbers
Title and affected asset	Clear name and exact in-scope asset
Severity	Critical / High / Medium / Low / Informational with rationale
Description	What was observed and why it matters
Evidence	Minimal redacted proof; no unnecessary personal data
Impact	Confidentiality, integrity and availability implications
Reproduction summary	Safe, limited steps sufficient for the owner to verify
Recommendation	Practical remediation and mitigation
Owner and due date	Named remediation owner and target date
Disclosure status	Received / validating / confirmed / remediation / retest / closed

6.4 Disclosure approaches compared

Approach	Meaning	Advantages	Limitations
Coordinated disclosure	Reporter and owner coordinate validation, fix and communication.	Protects users while allowing a fix; supports orderly communication.	Requires trust, timely responses and clear deadlines.
Full disclosure	Details are published publicly, often before or regardless of remediation.	Can create pressure for action and inform defenders.	May enable exploitation and expose users; not the default for university findings.
Bug bounty	An organized programme rewards eligible reports under published rules.	Encourages external reports and defines scope/reward rules.	Needs budget, triage capacity, clear exclusions and legal controls.

6.5 Decision and logging rules

- Use coordinated disclosure by default for university systems and personal-data findings.
- Do not authorize public disclosure of sensitive details while a material risk remains, unless legal counsel and the designated authority approve a justified communication plan.
- Consider faster public notification if users face immediate harm, exploitation is active or legal/contractual duties require notice; coordinate with legal and incident-response teams.
- Reject reports that demand payment through threats; preserve the message and escalate to legal/security leadership.
- Log every approval, validation result, severity change, owner, remediation date, exception and disclosure decision with timestamp and responsible person.

Interaction: the disclosure layer accepts findings only when linked to an engagement ID or an approved external-report intake. The RoE defines who may test and what evidence may be collected. Legal/privacy controls define what can be stored or disclosed.

TASK 7 – Design an Isolated Ethical-Hacking Lab

7.1 Lab architecture

The lab uses a host computer running a Type-2 hypervisor such as VirtualBox or VMware Workstation. Two virtual machines are created: Kali Linux as the tester machine and an intentionally vulnerable, university-approved target VM. Both virtual network adapters are attached to a host-only network with the reserved subnet 192.168.56.0/24. No bridged adapter is used. The lab has no route to the campus production network.

Component	Role	Example configuration
Host computer	Runs the hypervisor and stores VM files.	Host-only virtual switch enabled.
Kali Linux VM	Authorized assessment workstation.	192.168.56.10/24
Target VM	Isolated practice target with synthetic data.	192.168.56.20/24

Component	Role	Example configuration
Host-only network	Allows host and VMs to communicate privately.	192.168.56.0/24
Evidence folder	Stores screenshots, configuration and test notes.	Restricted folder; no real student data.

7.2 Configuration and verification operations

Operation 1 – Record the lab configuration: record hypervisor name/version, VM names, operating-system versions, allocated CPU/RAM, virtual NIC mode, MAC addresses, IP addresses, subnet, snapshots and date. Save screenshots of the host-only network settings and VM network adapters.

Operation 2 – Verify connectivity: start both VMs, confirm their assigned addresses, and perform a basic ping from Kali to the target. Record the command, result and timestamp. If connectivity fails, check that both adapters use the same host-only network and subnet. Do not change either adapter to bridged mode.

Example verification commands on Linux: `ip addr` to inspect addresses and `ping -c 4 192.168.56.20` to test connectivity. The commands are for the isolated lab only.

7.3 Host-only versus NAT

Feature	Host-only	NAT
VM-to-VM communication	Yes, when attached to the same host-only network.	Usually yes, depending on hypervisor network configuration.
Internet access	Normally no direct internet access.	Outbound internet access is commonly available through host NAT.
Isolation	Strong separation from external networks when configured correctly.	More convenient for updates, but has an outbound path.
Use in this programme	Preferred for hands-on security testing.	Use only when updates are necessary and under controlled conditions.

Chosen design: host-only. It provides the containment needed for practice and reduces the risk of accidentally reaching university systems or the public internet. If updates are required, use a controlled maintenance step, then disconnect the NAT adapter before testing. All lab targets must be intentionally provided and owned or licensed for practice.

TASK 8 – Develop a Reusable Document Library

The following document set is stored in a restricted programme repository. Each document has a version number, owner, creation date and retention rule.

8.1 Reusable documents

Document	Key fields	Purpose / integration
1. Assessment Request Form	Requester, department, business purpose, asset owner, assets, proposed dates, data types, third parties, urgency.	Starts the authorization workflow and receives an engagement ID.
2. Authorization and Consent Form	Engagement ID, approver authority, system owner, named testers, asset schedule, methods, dates, signatures, expiry.	Evidence that testing is permitted; checked before RoE is activated.
3. Rules of Engagement	In-scope/out-of-scope assets, methods, limits, testing window, data handling, stop conditions, escalation contacts.	Controls tester activity and defines the permitted evidence.
4. Vulnerability Finding Report	Finding ID, engagement ID, asset, severity, evidence, impact, recommendation, owner, due date, disclosure status.	Structured output feeds the disclosure register, remediation tracking and closure review.

8.2 Test entries and expected results

Test entry	Input condition	Expected result
Valid authorization	All required fields complete; valid approver and owner signatures; dates current.	Accept; assign ID; permit RoE preparation.
Boundary authorization	Approval expires at the end of the current day; test scheduled before expiry.	Accept only within the valid period; block any later activity.
Invalid authorization	Missing system-owner approval or unnamed target asset.	Reject; status 'NOT AUTHORIZED'; no testing.
Valid finding report	Finding linked to engagement ID, asset in scope, severity and evidence included.	Accept; create disclosure record and remediation task.
Invalid finding report	Report includes an asset not in scope or unredacted personal data.	Quarantine for review; do not distribute; escalate to lead/privacy contact.

Structured integration: the finding report exports a consistent record containing Finding ID, Engagement ID, Asset ID, Severity, Owner, Due Date and Status. The disclosure register uses these fields to track validation, remediation and closure.

TASK 9 – Integrate, Test and Refine the Framework

9.1 Integrated walkthrough

Stage	Walkthrough action	Framework evidence
Request	The LMS department requests a pre-upgrade assessment of a named test environment.	Assessment Request Form
Authorization	The system owner confirms ownership; governance checks approver authority; legal/privacy review is completed.	Signed authorization and compliance checklist
Scope	The team lists LMS test hostname and test accounts; production student database and third-party payment service are excluded.	Versioned RoE and asset schedule
Preparation	Testers sign the code of conduct; pre-engagement checklist is completed.	Checklist and tester register
Lab validation	A matching practice configuration is tested in the host-only lab using synthetic accounts.	Lab configuration record and connectivity evidence
Assessment	Only approved, non-disruptive checks are performed within the agreed window; actions are logged.	Activity log
Finding	A weakness is verified with minimal redacted evidence and assigned a severity.	Finding report
Disclosure	Security team acknowledges, informs the owner, sets remediation target and records status updates.	Disclosure register
Closure	Owner applies a fix; tester retests; evidence is securely retained or deleted under policy.	Retest result and closure approval

9.2 Systematic test cases

Test case	Expected framework behaviour
Missing authorization	Block all testing; mark NOT AUTHORIZED; notify requester of missing approval.
Out-of-scope request	Stop the requested activity; record the asset; require a signed scope amendment before any test.
Legal conflict or unclear jurisdiction	Pause the affected activity; refer to legal/privacy officers; proceed only after written resolution.
Delayed disclosure / overdue remediation	Escalate to security governance and system owner; record risk acceptance or mitigation; review whether user notification is required.
Unexpected personal-data exposure	Stop collection; restrict evidence; notify privacy contact; follow incident process.
Service instability	Stop testing immediately; alert owner; preserve logs and support recovery.

9.3 Problems found and refinements

Problem during walkthrough	Refinement
Asset name in request did not match the asset register.	Require stable Asset IDs and exact hostnames/IPs in the signed schedule.
An assessor could not tell whether approval was still valid.	Add automatic expiry field and pre-test revalidation.
Finding evidence contained unnecessary personal information.	Require redaction and minimum-proof review before report submission.
Disclosure deadline had no escalation owner.	Add named escalation owner and overdue status in the register.
External assessor responsibilities were unclear.	Add confidentiality, data-processing and subcontractor clauses to onboarding.

The final framework is reproducible because each stage has a named owner, a defined input, a controlled output and a record that can be reviewed.

TASK 10 – Create a Scalability and Governance Evaluation

10.1 Evaluation scenarios

Measure	Small programme	Large programme
Coverage	1 department; 3 systems; 5 testers	Whole university; 20 systems initially, scalable to 100; 25 internal/external testers
Approval workflow	One system owner and one governance reviewer	Multiple owners, central governance and third-party review
Scope review	One asset schedule	Department schedules consolidated under one asset register
Disclosure handling	One security contact and owner	Central triage team with assigned system owners and escalation
Records	Shared restricted register	Role-based central register with versioning and audit trail

10.2 Illustrative process measures

The figures below are planning estimates for comparing governance designs; they are not measured university results. A pilot should replace them with actual timestamps and counts.

Process	Small programme estimate	Large programme estimate	Interpretation
Approval turnaround	2 business days	5 business days	Large programme needs delegated approvals and standard risk tiers.
Scope review effort	1–2 review steps	3–4 review steps	A central asset register reduces repeated clarification.
Finding triage	1 business day	2 business days	A central triage queue and severity rules support consistent decisions.
Coverage tracking	3 of 3 systems	20 of 20 planned systems	Use Asset IDs and a dashboard to identify unassessed systems.

10.3 Structured comparison

The comparison shows that the same governance principles can be retained at both sizes, but large programmes require automation, delegated ownership, central tracking and more formal third-party onboarding. A single person should not approve, test and close the same engagement without independent review.

10.4 Governance refinements based on the evaluation

- Introduce risk-based approval tiers: low-risk lab checks use a simplified approval route; production or personal-data assessments require system-owner and legal/privacy review.
- Maintain a central asset register with owner, environment, data classification and third-party dependency.
- Use reusable forms and pre-approved RoE clauses to reduce repeated approval work.

- Create a central disclosure queue with severity-based service targets and overdue escalation.
- Give external assessors time-limited, named accounts and access only to the approved assessment environment.

A future pilot should record actual approval timestamps, number of scope changes, systems assessed, findings triaged within target and overdue remediation cases. The university can then compare measured performance with the planning estimates.

TASK 11 – Defend the Framework Under a Changed Requirement

11.1 Changed requirement

The university now requires continuous assessments, third-party assessors, stricter data-protection controls, shorter disclosure timelines and a framework that remains easy to govern and extend.

11.2 Retain, modify, replace or redesign

Component	Decision	Reason / change
Authorization	Modify	Use standing programme authorization for a defined period, but require a separate engagement record and asset-owner approval for each assessment.
Scope and RoE	Modify	Add continuous-testing windows, rate limits, approved automation, change notifications and automatic expiry.
Legal/privacy mapping	Strengthen	Require data classification, privacy impact review where appropriate, processor terms and a commencement check for applicable data-protection provisions.
Threat model and ethics	Retain and update	Add risks from automated scanners, supply-chain access and third-party personnel.
Isolated lab	Retain	Continue using host-only lab for hands-on practice and regression testing.
Disclosure	Redesign	Introduce severity-based shorter targets, rapid critical escalation and a live status register.
Document library	Modify	Use controlled digital templates, mandatory fields, version history and role-based access.

11.3 New component: Continuous Assessment Control

Control	Operation
Approved asset inventory	Only registered assets can be scanned; each asset has an owner, environment and data classification.
Schedule and rate limits	Automated checks run only in approved windows with system-owner-defined request limits.
Change detection	New or changed assets are not automatically tested; they enter a review queue until approved.
Third-party access	Named assessors use time-limited accounts, MFA where available, confidentiality terms and restricted evidence folders.
Data minimization	Prefer configuration metadata and synthetic data; block bulk extraction and mask identifiers in reports.
Rapid disclosure	Critical findings are immediately escalated; proposed targets are acknowledge within 1 business day, triage within 2 business days and agree urgent mitigation without delay.
Audit and stop	All runs, approvals, scope changes, exceptions and stop events are logged; owners can pause an assessment.

11.4 Integration with existing framework

The continuous assessment control reads the approved asset register and authorization record. It checks the RoE before each scheduled run. The legal/privacy module determines whether the asset may contain personal data and which safeguards apply. Findings are sent to the same disclosure register and assigned a severity-based timeline. The isolated lab remains the place for hands-on validation where production testing would be unsafe.

11.5 Evidence-based defence

- The Task 9 walkthrough demonstrates that request, approval, scope, testing, reporting and closure can operate as one controlled process.
- The Task 10 comparison shows why central asset tracking, reusable templates and delegated approval are needed as the number of systems and assessors increases.
- The legal mapping identifies controls for unauthorized access, disclosure and digital personal data, while recognizing phased commencement and jurisdictional limits.
- The disclosure process provides owners, target dates, status logging and escalation, which can be tightened for critical findings under the changed requirement.

11.6 Remaining trade-offs and future improvements

Trade-off / limitation	Future improvement
More approvals and privacy checks can slow assessments.	Use risk-based tiers, pre-approved templates and service-level targets without removing mandatory safeguards.
Continuous scanning may create false positives or operational load.	Pilot in a test environment, tune rate limits, monitor service health and require human validation.
External assessors increase coordination and data-handling risk.	Use supplier due diligence, time-limited access, contractual controls and periodic access reviews.
Shorter disclosure timelines may be difficult for complex fixes.	Use compensating mitigations, documented risk acceptance and frequent status updates while permanent fixes are developed.

Final defence: the framework is suitable because it makes permission, scope, privacy, safety and disclosure explicit and auditable. It scales through standard documents, asset IDs, delegated ownership and a central register. The framework does not treat authorization as unlimited permission: every assessment remains limited by the approved systems, methods, dates and applicable law.

Conclusion

The proposed university ethical-hacking engagement framework provides a complete governance process from request to closure. It identifies relevant hacker threats, establishes a code of conduct, maps legal responsibilities, defines scope and rules of engagement, formalizes authorization and coordinated disclosure, and uses an isolated host-only lab for safe practice. Reusable documents and validation tests make the process repeatable. The scalability evaluation and changed-requirement design show how the framework can expand to continuous and third-party assessments while maintaining accountability and protection of university data.

References

- Government of India, The Information Technology Act, 2000, India Code.
- Government of India, The Digital Personal Data Protection Act, 2023, India Code.
- Government of India, Gazette notification on phased commencement of the Digital Personal Data Protection Act, 2023, 13 November 2025.
- United States Code, Title 18, Section 1030 – Fraud and related activity in connection with computers (Computer Fraud and Abuse Act).
- Assignment brief: ITA14 Ethical Hacking – Assignment 1, CO1.